UNIT 4 · TOPIC 4.1

Device Vulnerabilities and Attacks

Quiz

Instructions: This quiz has 18 multiple-choice questions, 1 point each. Circle the letter of the single best answer for each question.

Name: **Date:** **Class:**

1. A security team investigates an internet-connected tractor after its autopilot begins moving to unauthorized GPS coordinates. Forensic review reveals hidden software that silently collects location data and transmits it to an external server at regular intervals. Which type of malware best describes this threat?

- ○ A. Ransomware, because the software is encrypting the GPS configuration files.
- ○ B. Worm, because the software replicates itself across other devices on the farm network.
- ○ C. Spyware, because the software covertly collects and exfiltrates data without the user's knowledge.
- ○ D. Logic bomb, because the software activates only when a specific condition is met.

2. An automated milking machine's onboard computer is observed making periodic outbound connections to a cluster of unfamiliar IP addresses, transmitting small data packets at regular intervals even when idle. No legitimate application accounts for this traffic. Which malware classification most accurately describes this behavior?

- ○ A. Rootkit, because the malware is hiding system files from administrators.
- ○ B. Bot, because the device appears to be under remote command-and-control as part of a botnet.
- ○ C. Trojan, because the malware disguised itself as legitimate firmware to be installed.
- ○ D. Adware, because the device is generating unsolicited network traffic.

3. Following a cyberattack, an irrigation controller's stored configuration files are encrypted and access is blocked. A message appears on the management dashboard reading: "Your device data has been locked. Send 0.5 BTC to [address] within 72 hours to recover your files." Which malware type was used in this attack?

- ○ A. Spyware, because the attacker is collecting information from the device.
- ○ B. Backdoor, because the attacker established persistent unauthorized access to the device.
- ○ C. Keylogger, because the attacker captured keystrokes to obtain admin credentials.
- ○ D. Ransomware, because the attacker has encrypted data and is demanding payment for its restoration.

4. A GPS-guided tractor's remote management interface is exposed to the internet and uses factory-default credentials (username: admin / password: admin) that were never changed after deployment. Which of the following most accurately explains how an adversary could exploit this vulnerability to cause disruption?

- ○ A. The adversary logs directly into the management interface using the publicly documented default credentials, then alters GPS waypoints or installs malware, requiring no technical sophistication.
- ○ B. The adversary performs a brute-force dictionary attack requiring thousands of attempts before gaining access.
- ○ C. The adversary sends a phishing email to the farmer to harvest their personal banking credentials.
- ○ D. The adversary exploits a buffer overflow in the GPS satellite receiver firmware to inject arbitrary code.

5. An agricultural-tech company's irrigation management systems use unencrypted HTTP for their web-based control interface, transmitting operator credentials and device commands in plaintext over the farm's Wi-Fi network. How can an adversary on the same network exploit this insecure configuration?

- ○ A. The adversary can overflow the irrigation controller's memory by sending a large number of HTTP packets simultaneously.
- ○ B. The adversary can install ransomware by sending a malicious email attachment to the farm operator.
- ○ C. The adversary can perform a man-in-the-middle attack, intercepting and reading credentials and commands in plaintext, and potentially injecting their own commands.
- ○ D. The adversary can physically remove the controller's storage media while the system is running.

6. A connected tractor's embedded network stack runs firmware version 2.1.0, which contains a publicly disclosed buffer overflow vulnerability in the packet-parsing routine. A patch has been available for six months but was never applied. Which attack technique would an adversary most likely use to exploit this specific vulnerability?

- ○ A. Sending a specially crafted network packet that overflows the input buffer, corrupting adjacent memory and allowing the adversary to execute arbitrary code.
- ○ B. Social engineering the farm operator by phone to reveal the device's admin password.
- ○ C. Performing an online brute-force attack against the tractor's web management login page.
- ○ D. Intercepting GPS satellite uplink signals to inject false positioning data.

7. A security engineer assesses three vulnerabilities in a fleet of internet-connected tractors: (1) Remote management interface accessible over the public internet using documented default credentials. (2) Firmware update packages transmitted over the network without cryptographic signing or integrity verification. (3) GPS telemetry data transmitted in plaintext over Wi-Fi. Using a likelihood × impact framework, which risk ranking is best supported?

- ○ A. GPS telemetry (highest) > firmware signing (medium) > default credentials (lowest), because GPS exposure directly threatens physical farm operations.
- ○ B. Default credentials (highest) > firmware signing (medium) > GPS telemetry (lowest), because default credentials are trivially exploitable with maximum likelihood and grant full system control.
- ○ C. All three vulnerabilities are equally critical and must be addressed simultaneously before any ranking can be assigned.
- ○ D. Firmware signing (highest) > default credentials (medium) > GPS telemetry (lowest), because unsigned firmware affects every device update cycle regardless of credential policy.

8. A security engineer documents a risk for internet-connected milking machines running embedded Linux firmware with 12 unpatched CVEs, three of which are rated 9.0–9.8 CVSS and allow unauthenticated remote code execution over the public internet. Which risk assessment conclusion is most accurate?

- ○ A. Risk level: Critical. Three unauthenticated RCE vulnerabilities with CVSS scores above 9.0 represent near-certain exploitability and the potential for full device compromise, physical damage, and safety violations.
- ○ B. Risk level: Low. The machines are in a private barn environment and are unlikely targets for sophisticated adversaries.
- ○ C. Risk level: Medium. CVSS scores reflect theoretical severity and actual exploitability in the field is typically much lower than the base score suggests.
- ○ D. Risk level: High, but acceptable because patching embedded operational technology mid-season is operationally disruptive and the risk is offset by physical isolation.

9. An adversary exploited default credentials on 40 irrigation controllers, installed spyware, and exfiltrated six months of crop-planning, scheduling, and chemical-application data. The devices remain operational but are fully compromised. Using a likelihood × impact risk documentation framework, which post-incident entry is most complete and accurate?

- ○ A. Threat: External. Likelihood: Low (attack required sophisticated knowledge of agricultural systems). Impact: Low (only data was accessed; equipment remains operational). Risk: Low.
- ○ B. Threat: External. Likelihood: High (default credentials are trivially exploitable and publicly known). Impact: High (sensitive operational data exfiltrated; persistent compromise enables follow-on sabotage; regulatory notification may be required). Risk: Critical.
- ○ C. Threat: Internal. Likelihood: Medium. Impact: Medium. Risk: Medium. Attacker required local access to install spyware on the controllers.
- ○ D. Threat: External. Likelihood: High. Impact: Low (data breach only; no physical disruption occurred). Risk: Medium.

10. Which of the following best describes an Internet of Things (IoT) device?

- ○ A. A high-performance server in a data center running a virtualization hypervisor to host multiple virtual machines.
- ○ B. A dedicated hardware firewall appliance managing inbound and outbound enterprise network traffic.
- ○ C. A standard desktop computer running a general-purpose operating system with user productivity applications.
- ○ D. A network-connected physical device with embedded sensors or actuators designed to interact with or monitor the physical world.

11. A GPS-guided tractor's onboard computer is designed to run a single real-time control program, accepts sensor input from GPS and proximity sensors, and has 512 MB of RAM. It cannot be easily reconfigured to run general applications. Which computing device category does this best represent?

- ○ A. General-purpose personal computer (PC)
- ○ B. Mainframe terminal
- ○ C. Thin client
- ○ D. Embedded system / Industrial IoT (IIoT) device

12. Which of the following is NOT a typical characteristic of IoT and embedded devices compared to standard general-purpose computers?

- ○ A. Constrained processing power and limited RAM
- ○ B. Designed to perform a specific, narrow set of tasks
- ○ C. Often connected to a network or the internet
- ○ D. Runs a full general-purpose operating system with a wide range of user-installable applications

13. A fleet of connected tractors runs firmware version 2.1.0, which contains an unpatched privilege escalation vulnerability. A patch has been available for eight months. Which statement best explains why privilege escalation is a particularly severe risk in an operational technology (OT) context such as internet-connected farm equipment?

- ○ A. Privilege escalation lets an adversary elevate a low-privileged foothold to full system control, enabling them to modify control logic, disable safety interlocks, or install persistent malware, potentially causing physical damage.
- ○ B. Privilege escalation allows an adversary to create additional user accounts, which is time-consuming to remediate but does not affect device operation.
- ○ C. Privilege escalation is only relevant on multi-user systems and does not apply to single-purpose OT devices.

○ D. Privilege escalation primarily affects data confidentiality and has minimal impact on device availability or physical-world integrity.

14. An agricultural-tech company's milking machine management software includes a diagnostic interface that allows technicians to run system checks. The interface passes user-supplied input directly to the underlying operating system shell without sanitization or input validation. How could an adversary exploit this insecure configuration?

○ A. By injecting operating system commands through the diagnostic interface input field to execute arbitrary code with the application's privilege level.

○ B. By sending phishing emails to farm employees to obtain their VPN credentials and then connecting remotely.

○ C. By intercepting firmware update packages in transit and substituting them with malicious versions.

○ D. By flooding the diagnostic interface with requests to cause a denial-of-service condition.

15. Connected irrigation controllers in a farm network share a network VLAN with the farm's office computers. An adversary who has already compromised one office workstation can reach and send commands to any irrigation controller directly, with no additional credentials required. Which device vulnerability does this scenario most clearly illustrate?

○ A. Insecure network segmentation, enabling lateral movement from the IT (office) environment into the OT (control) environment.

○ B. Weak authentication on the irrigation controllers allowing unauthenticated command execution.

○ C. Unencrypted data transmission on the irrigation controller management interface.

○ D. Absence of physical locks on office workstations, allowing unauthorized physical access.

16. A security engineer is completing a risk register entry for a fleet of 40 internet-connected GPS-guided tractors. The tractors run firmware v2.1.0, which has a publicly disclosed RCE vulnerability (CVE available, proof-of-concept exploit code published). A patch has been available for six months and was never deployed. Which risk register entry is most complete and professionally accurate?

○ A. Risk ID: R-04 | Asset: Tractor fleet | Threat: Cyberattack | Vulnerability: Old firmware | Likelihood: Possible | Impact: Significant | Risk Level: High | Recommendation: Update firmware when convenient.

○ B. Risk ID: R-04 | Asset: Tractors | Threat: Hackers | Vulnerability: Software bugs | Likelihood: Unknown | Impact: Unknown | Risk Level: Medium | Recommendation: Annual review.

○ C. Risk ID: R-04 | Asset: Firmware version | Threat: Malware | Likelihood: Low | Impact: Medium | Risk Level: Low | Recommendation: Monitor the situation.

○ D. Risk ID: R-04 | Asset: Tractor fleet (40 units, field-deployed) | Threat: Remote adversary exploiting published RCE CVE via network | Vulnerability: Firmware v2.1.0, unpatched 6 months post-disclosure, public PoC available | Likelihood: High (public PoC lowers exploit barrier to script-kiddie level) | Impact: Critical (full device control; physical damage, crop loss, and safety incidents possible) | Risk Level: Critical | Recommendation: Emergency patching within 30 days; interim control: restrict management interfaces to internal VLAN and disable public internet exposure immediately.

17. A security engineer must present device vulnerability risks to executive leadership at an agricultural-tech firm. Format 1 is a technical CVE list with CVSS vector strings, exploit complexity ratings, and CWE classifications. Format 2 maps each vulnerability to business impact (crop loss, equipment damage, regulatory fine risk, reputational harm), with likelihood ratings and specific recommended mitigations. Which format best fulfills the objective of "document risks from device vulnerabilities" for a non-technical decision-making audience?

- ○ A. Format 1 only, because technical precision is always superior in security risk documentation and executives should learn to read CVE data.
- ○ B. Both formats are equivalent; the choice is purely a matter of personal preference.
- ○ C. Neither format, risk documentation should only be delivered verbally to avoid creating discoverable evidence in the event of litigation.
- ○ D. Format 2 only, because documenting risk for decision-makers requires translating technical findings into business impact, likelihood, and actionable recommendations, which is exactly what risk documentation is for.

18. After completing a device vulnerability assessment, a security engineer documents two risks:
Risk A, default credentials on 40 tractors' management interfaces (rated Critical); remediation cost: $500 and 1 hour per device ($20,000 total, completable in one week).
Risk B, unencrypted GPS telemetry (rated High); remediation cost: $200,000 firmware redesign, estimated 9-month timeline.
How should cost and effort information be incorporated into the risk register, and what remediation priority order follows?

- ○ A. Include remediation cost and timeline in the risk register alongside risk level, enabling stakeholders to identify that Risk A (Critical, low cost, fast) should be addressed immediately while Risk B (High, high cost, long timeline) is planned and tracked separately. Prioritize Risk A first.
- ○ B. Do not include cost in the risk register; remediation cost is a business decision outside the scope of risk documentation. Prioritize by risk rating alone: Risk A first.
- ○ C. Prioritize Risk B first, because the larger investment signals that it is the more serious problem.
- ○ D. Mark both risks as acceptable until budget is available, since neither can be remediated without organizational approval.